PentAGI

中文使用手册

自主渗透测试平台 · Docker Compose 部署 · v2.2.0

适用版本：PentAGI 2.2.x（CE）

编写日期：2026 年 10 月

适用范围：单机 Docker 部署、内网访问、中文界面

目录

1 这是什么
1.1 能力边界
1.2 和常见工具的区别
2 部署架构与资源要求
2.1 最低配置
3 安装
3.1 方式一：官方安装器
3.2 方式二：compose 手动部署
4 首次登录与基础设置
4.1 登录
4.2 界面导览
5 配置模型服务商
5.1 内置服务商
5.2 自定义（OpenAI 兼容）
5.3 OpenCode Go 的两个坑
5.4 接入 DeepSeek（推荐首选）
6 跑第一个任务流
6.1 创建
6.2 执行过程怎么看
6.3 写指令的建议
7 模板、资源库与知识库
7.1 模板
7.2 资源库
7.3 知识库
8 报告与导出
9 日常运维
9.1 启停与状态
9.2 升级
9.3 备份
9.4 日志与资源
10 安全与合规
11 常见问题
11.1 启动时报端口被占用
11.2 镜像拉取很慢或失败
11.3 模型连不上 / 一直重试
11.4 任务卡住或反复调同一个工具
11.5 内存不足 / 容器反复重启
11.6 界面想用中文
附录 A 环境变量速查
附录 B 默认端口与目录
附录 C 参考链接与版本记录
版本记录

1 这是什么

PentAGI 是一个可自托管的多 Agent AI 渗透测试平台。你用自然语言描述目标和任务，它在隔离的 Docker 沙箱里调用 nmap、Metasploit、sqlmap 等工具，自己规划步骤、执行、记录，最后给出带漏洞说明和复现步骤的报告。

它不替代渗透测试工程师，定位是“把重复的侦察、验证、记录工作自动化”，适合授权范围内的例行评估、复测、演练前自查。

1.1 能力边界

能做	不能做 / 注意事项
Web/API 黑盒测试、内网资产发现、口令与漏洞验证、攻击路径记录	不做破坏性操作；不保证覆盖全部漏洞
把每一步命令、输出、截图留存，便于复盘和出报告	需要人工复核漏洞真实性，避免误报
多 Agent 协作：侦察、执行、总结分工	复杂目标仍需人定边界、盯过程
接入本地或云端大模型（13 种内置服务商 + 任意 OpenAI 兼容端点）	模型能力直接决定效果，弱模型容易绕圈

> 仅在获得书面授权的目标上使用。平台会在沙箱里执行真实攻击命令，未经授权使用可能违法。

1.2 和常见工具的区别

和扫描器相比，它不是按规则库打点，而是“理解目标 → 决定下一步 → 执行 → 看结果再调整”；和单 Agent 脚本相比，它有任务分解、子任务、记忆和上下文压缩，能跑更长的流程，也更容易在卡住时自我纠偏。

2 部署架构与资源要求

整套服务用 Docker Compose 编排，主要容器如下：

容器	作用	默认端口
pentagi	主服务：Web UI + API + Agent 调度	8443（HTTPS）
pgvector	PostgreSQL + 向量扩展，存任务、日志、记忆	127.0.0.1:5432
scraper	隔离浏览器，抓取网页	127.0.0.1:9443
pgexporter	数据库指标导出（可选）	127.0.0.1:9187
沙箱容器	每个任务流一个，执行攻击命令，用完销毁	28000–29999（OOB 回调）

2.1 最低配置

- CPU：2 核以上；内存：4 GB 以上（实际跑任务建议 8 GB）

- 磁盘：20 GB 以上（镜像约 2–3 GB，任务数据持续增长）
- 系统：Linux x86_64 / arm64，Docker 20.10+ 与 compose 插件
- 网络：能访问模型 API；内网可访问 8443

3 安装

官方提供交互式安装器，也支持手工 compose。两者最终都是起同一套容器；国内网络下载安装器可能很慢，可以直接用 compose 方式。

3.1 方式一：官方安装器

```
mkdir -p pentagi && cd pentagi
curl -fL -O https://pentagi.com/downloads/linux/amd64/installer-latest.zip
unzip installer.zip && chmod +x installer
sudo ./installer
```

安装器会依次询问：大模型服务商与 Key、搜索服务、监听端口（默认 8443）、管理员账号。

3.2 方式二：compose 手动部署

```
mkdir -p /opt/pentagi && cd /opt/pentagi
# 需要的文件：docker-compose.yml、.env、三个 provider 示例 yml
curl -O https://raw.githubusercontent.com/vxcontrol/pentagi/main/docker-compose.yml
cp .env.example .env
sudo docker compose pull && sudo docker compose up -d
```

如果宿主机 5432 已被占用（fnOS 自带 PostgreSQL 常见），把 .env 里的 PGVECTOR_LISTEN_PORT 改成 15432，POSTGRES_EXPORTER_LISTEN_PORT 改成 19187，SCRAPER_LISTEN_PORT 改成 19443，再启动。

> 容器内部通过 docker 网络互相访问（pgvector:5432），宿主机端口只是映射，改掉不影响功能。

4 首次登录与基础设置

4.1 登录

浏览器打开 https://<服务器 IP>:8443。证书是自签的，浏览器会提示不安全，选择继续访问即可。

默认管理员：admin@pentagi.com / admin。首次登录后立即在「设置 → 账户」修改邮箱和密码。

4.2 界面导览

区域	用途
仪表盘	任务流数量、Token 用量、成本、工具调用趋势，按周/月/季度看
任务流	创建与查看渗透任务，实时看任务分解、Agent 日志、终端输出、截图
模板	把常用的任务描述存成模板，下次一键套用

区域	用途
资源库	上传字典、源码、文档等，任务执行时 Agent 可引用
知识库	沉淀方法论、历史结论，写入向量库供检索
设置	账户、模型服务商、提示词、API 令牌

5 配置模型服务商

平台本身不含模型，必须先接入至少一个大模型。入口：设置 → 模型服务商 → 新建服务商。

5.1 内置服务商

服务商	填写内容	备注
DeepSeek	API Key；地址默认 https://api.deepseek.com	性价比高，适合入门
智谱 GLM	API Key；地址 https://api.z.ai/api/paas/v4	国内直连稳定
Kimi	API Key；地址 https://api.moonshot.ai/v1	长上下文
通义千问	API Key；DashScope 兼容地址	国内可选
OpenAI / Anthropic / Gemini	对应 Key	需外网
Ollama	本地服务地址，如 http://宿主机 IP:11434	无 Key，需显卡

5.2 自定义（OpenAI 兼容）

任何提供 /v1/chat/completions 的服务都能接：类型选“自定义”，填 Base URL、Key、模型名。例如 OpenCode 的推理端点：

```
Base URL: https://opencode.ai/inference/v1
Key: OpenCode Console 创建的 personal API key
模型：deepseek-v4.1-flash、kimi-k3 等（仅 chat/completions 系列）
```

Base URL 用不带 /openai 的地址：模型列表接口是 /inference/v1/models，带 /openai 会 404，界面里就会显示「No model found」。

保存后点“测试”，每个 Agent 角色（顾问、编码、渗透、总结等）可以分别指定模型。省钱做法：主 Agent 用强模型，去重/总结用小模型。

> 平台会按角色调用模型十几次甚至几十次，“测试”通过不代表复杂任务一定能跑完，先用小目标验证。

5.3 OpenCode Go 的两个坑

① 订阅额度不等于 API 额度。OpenCode Go 覆盖的是 OpenCode 自家客户端（CLI / 桌面端）的用量；把同一个 Key 拿到外部客户端（如本平台）调用 /inference 接口时，仍按 token 计费，账户余额为 0 会直接返回：

```
402 Payment Required
Upstream request failed: Insufficient account funds
```

要外部调用，需要去 Console → Extra usage 打开按量计费并充值（最低 5 美元）。控制台里显示的「Rolling / Weekly / Monthly 已用百分比」是客户端用量，不代表 API 有余额。

② 带 -free 后缀的模型只允许 OpenCode 客户端调用，外部调用返回 403；要外部可用，必须选付费/订阅覆盖的模型。

③ 想省钱又不想充值，可以另配一个直连服务商（如 DeepSeek），和 OpenCode Go 并存，哪个额度多用哪个。

5.4 接入 DeepSeek（推荐首选）

DeepSeek 国内直连、按量计费、单价低，适合先把平台跑通。完整步骤：

- platform.deepseek.com 注册并充值（10 元起），左侧「API keys」→ 创建 API key。
- 创建弹窗里立即完整复制（sk- 开头共 35 位）。关掉弹窗后列表只显示带 * 的掩码，再复制那串就会 401。
- 写入 .env：DEEPSEEK_API_KEY=完整 Key，然后 docker compose up -d --force-recreate pentagi。
- 界面 → 设置 → 模型服务商 → 新建，类型选 deepseek，模型填 deepseek-chat，测试通过后创建。

> 报错对照：401 多为复制了掩码或带了空格（用 echo 长度 应为 35）；402 是余额不足；404 是模型名写错。deepseek-chat 实际可能路由到 flash 版本，属正常。

6 跑第一个任务流

6.1 创建

任务流 → 新建任务流，页面有两种模式：

- 自动化：给目标和一句话任务，Agent 自主规划并执行，适合“对某站点做黑盒测试”这类目标明确的任务
- 助手 Agent：对话式，适合边聊边确认、逐步推进

在输入框写清目标，例如：对 http://10.0.0.5:8080 做黑盒渗透测试，重点关注越权、SQL 注入文件上传；只测试该地址，不要扫描同网段其他主机；输出中文报告。

6.2 执行过程怎么看

- 任务页：左侧是任务/子任务树，右侧是当前 Agent 的命令与输出
- Agent 日志：每个角色的思考与工具调用，可搜索
- 终端：沙箱里的真实 shell 输出
- 截图：Agent 用浏览器访问目标时抓的页面
- 随时可以「停止」，结束时点「结束」销毁沙箱

6.3 写指令的建议

- 明确边界：只测哪些域名/IP/端口，禁止扫描其他资产
- 明确禁止项：不删数据、不上传后门、不做拒绝服务
- 明确产出：要哪些内容（漏洞名称、位置、复现步骤、证据、修复建议）、按什么排序
- 给凭据：需要登录态时，在指令里写测试账号密码

7 模板、资源库与知识库

7.1 模板

把重复使用的任务描述（例如“政务云等保三级 Web 自查”）存成模板，下次新建任务流时直接选，减少重复描述。

7.2 资源库

上传字典、接口文档、源码包等，Agent 在任务中可以读取。支持文件夹、拖拽上传，单文件 300 MB、单次 2 GB。

7.3 知识库

把方法论、历史漏洞结论、客户环境说明写成知识条目，平台会向量化，Agent 规划时检索。条目类型：指南、答案、代码等。

8 报告与导出

任务流跑完后，报告页可以：

- 网页查看：漏洞列表、证据、攻击链、Token 与成本统计
- 导出 Markdown / PDF：直接给客户或存档
- 复制内容：粘到自己的报告模板里二次加工

> 报告语言跟随指令。中文报告请在任务描述或提示词里明确写“报告与漏洞说明使用简体中文”。

9 日常运维

9.1 启停与状态

```
cd /opt/pentagi
docker compose ps          # 看状态
docker compose restart     # 重启
docker compose down        # 停止（保留数据）
docker compose down -v     # 停止并删除数据卷（慎用）
```

9.2 升级

```
cd /opt/pentagi
docker compose pull && docker compose up -d
# 数据库迁移在启动时自动执行；升级前建议先备份
```

9.3 备份

```
# 备份数据库（任务、报告、记忆都在里面）
docker exec pgvector pg_dump -U postgres pentagidb > backup-$(date +%F).sql
# 备份配置
cp .env docker-compose.yml /path/to/backup/
```

9.4 日志与资源

```
docker compose logs -f pentagi        # 主服务日志
docker stats --no-stream              # 资源占用
docker system df                      # 镜像/卷占用
```

单次任务流会拉起沙箱容器，结束时销毁；如果发现沙箱堆积，检查是否有未结束的任务流。

10 安全与合规

- 授权：只对书面授权的目标使用，任务描述里写明边界
- 隔离：沙箱默认不挂宿主机 Docker socket（DOCKER_INSIDE=false）；不要为了图方便打开，历史上曾有因挂载 socket 导致的逃逸漏洞（CVE-2026-14784，2.2.0 已修复）
- 端口：8443 默认只监听 127.0.0.1，需要局域网访问才改成 0.0.0.0，并用防火墙限制来源
- 密钥：模型 Key 存在容器环境变量和 .env 里，注意文件权限（chmod 600），不要提交到代码库
- 数据：任务日志可能含目标敏感信息，导出和共享前先脱敏

11 常见问题

11.1 启动时报端口被占用

常见是 5432。改 .env 里的 PGVECTOR_LISTEN_PORT（如 15432）、POSTGRES_EXPORTER_LISTEN_PORT、SCRAPER_LISTEN_PORT 后重新 up -d。

11.2 镜像拉取很慢或失败

配置 Docker 镜像加速，或先在能正常拉取的机器上 docker save / docker load。pentagi.com 的安装器下载也很慢，可改用 compose 方式。

11.3 模型连不上 / 一直重试

先在“服务商 → 测试”里验证连通性；确认 Base URL 是否带 /v1、模型名是否存在于该账号；国内访问 OpenAI/Anthropic 需代理。

11.4 任务卡住或反复调同一个工具

弱模型容易绕圈。换更强的模型；或在设置里提高执行监控强度（EXECUTION_MONITOR_ENABLED）、开启任务规划（AGENT_PLANNING_STEP_ENABLED）。

11.5 内存不足 / 容器反复重启

沙箱和数据库都吃内存。至少给 8 GB；限制同时运行的任务流数量；关闭不用的 Graphiti、Langfuse 可选组件。

11.6 界面想用中文

官方无中文界面。可用前端覆盖层方案（挂载翻译脚本，右下角切换 EN/中文），不改镜像、升级后重新挂载即可。

附录 A 环境变量速查

变量	说明	示例
PENTAGI_LISTEN_IP / PORT	Web 监听地址与端口	0.0.0.0 / 8443
PUBLIC_URL / CORS_ORIGINS	对外访问地址与跨域来源	https://192.0.2.10:8443
DEEPSEEK_API_KEY 等	各服务商密钥	sk-...
LLM_SERVER_URL / KEY / MODEL	自定义 OpenAI 兼容端点	https://.../v1
PENTAGI_POSTGRES_PASSWORD	数据库密码	随机串
DOCKER_PORTS_BASE	沙箱 OOB 回调端口起始	28000
DOCKER_INSIDE	沙箱内是否可用 Docker	false（默认）
EXECUTION_MONITOR_ENABLED	执行监控（防绕圈）	true
AGENT_PLANNING_STEP_ENABLED	任务规划	true

附录 B 默认端口与目录

项目	默认值
Web UI	https://IP:8443
数据库	127.0.0.1:5432（容器内 pgvector:5432）
抓取服务	127.0.0.1:9443
沙箱回调端口	28000–29999
安装目录（compose 方式）	/opt/pentagi 或自定义
默认账号	admin@pentagi.com / admin（首次登录必须改）

附录 C　参考链接与版本记录

资源	地址
GitHub 仓库	https://github.com/vxcontrol/pentagi
官方文档	仓库 README 与 docs 目录（英文）
DeepSeek 开放平台	https://platform.deepseek.com
智谱开放平台	https://open.bigmodel.cn
Moonshot 开放平台	https://platform.moonshot.ai
Docker 文档	https://docs.docker.com

版本记录

版本	日期	说明
v1.0	2026-10	初版：覆盖部署、模型配置、任务流、报告、运维与常见问题
v1.1	2026-10	补充 OpenCode Go 402/404 排错与 DeepSeek 接入步骤

本手册基于 PentAGI 2.2.x 官方文档与实际部署整理，界面细节以你运行的版本为准。